

Кандидат 6

DevSecOps

Профессиональный опыт

000

DevSecOps

Сентябрь 2023 — Апрель 2024 (8 месяцев)

Внедрение и поддержание существующего ci, внедрение инструментов, разработка roadmap

000

AppSec

Июнь 2022 — Август 2023 (1 год 3 месяца)

000

AppSec

Декабрь 2021 — Март 2022 (4 месяца)

Фин.тех

Senior Application Security Engineer

Март 2021 — Декабрь 2021 (10 месяцев)

Работа в команде над построение SDLC в компании.

Взаимодействие с командами разработки(больше 100 команд)

Разработка обучающего курса для компании, создание и поддержка платформы для обучения.

Интегрирование платформы Owasp Juice Shop для внутреннего обучения.

Внедрение - CodeQL

Внедрение - Dependency Track

Внедрение ZAP

Создание и поддержка Security Baselines (Web Application Baseline, Mobile Application Baseline, Environment Baseline)

Создание и поддержка Reviewer Checklist.

Консультирование разработчиков, менеджеров, QA инженеров по вопросам информационной безопасности.

Работа с kubernetes для внедрения в инфраструктуру различных инструментов и платформ.

Составление Road Map и следование по ней.

Проведение и согласование trial run.

Постановка задач.

000

Application Security Manager

Июль 2019 — Декабрь 2020 (1 год 6 месяцев)

Внедрение и автоматизация мер безопасности в цикле безопасной разработки (SDLC);

Работа и внедрение DAST инструментов такими как ZAP, Wallarm, Burp Enterprise.

Работа и внедрение с SAST инструментами такими как Sonarqube.

Работа с SCA инструментами такими как Dependency-Check, Dependency-Track

Работа с Jira и Confluence.

Совместная работа с DevOps инженерами по внедрению данных инструментов в CI/CD pipeline Gitlab.

Совместная работа с QA тестировщиками при проведении смоук и регрессионного тестирования. Выявление уязвимых пакетов, используемых разработчиками.

Проведение тестирования безопасности приложений перед каждым релизом, а также регулярные проверки в ручном режиме с помощью Burp Suite.

Контроль задач в Jira связанных с безопасностью приложения, контроль за выполнением и последующие тестирование.

Подготовка стратегии тестирования на релиз.

Проведение обучения сотрудников в виде еженедельных вебинаров, подготовка презентаций, консультирования по вопросам безопасности.

Совместная работа с Team Lead и командами для внедрения различных мер защиты.

Создание корпоративной базы, связанной с безопасностью и различными атаками.

Понимание процесса цикла разработки.

Подготовка отчетов о проделанной работе как для внутреннего использования, так и для топ менеджмента, анализе защищённости, результатов работы различных сканеров и.т.д

Анализ рисков и моделирование веб-угроз приложения.

ooo

Специалист по тестированию безопасности информационных систем

Май 2018 — Июль 2019 (1 год 3 месяца)

Проведение тестирования на проникновение как внешние так и внутреннее. Разработка инструкций а также использование социальной инженерии в проектах. Уверенная работа с

Metasploit, Powershell Empire, Burp Suite, Responder, Inveigh, Aquaton, dirsearch, Mimikatz, Gophish, Wireshark, PowerView, PowerSploit, Sqlmap, XSSStrike, и другими. Понимание структуры AD, повышение привилегий в AD, разведка AD, использование различных атак на контроллер домена таких как DCSync, DCShadow, DPAPI и других. Получение доступа к критическим элементам - NAS, гипервизоры, базы данных, 1С. Понимание работы SMB, ssh, http, https, soap, RDP. Уверенный пользователь Linux и Windows. Понимание методов обнаружения атаки на AD. Повышение привилегий на Linux. Поиск уязвимостей в веб приложениях, участие в Bug Bounty программах.

Понимание и использование методологии OWASP. Понимание и опыт работы с такими уязвимостями как XSS, XXE, SQL inject, RCE, сериализация в PHP Ruby Java, атаки на JWT web tokens, CBC-MAC, уязвимости связанные с GIT, CSRF, обход CSP, CORS, LFI, RFI, Subdomain Takeover, GraphQL inject. Нахождение конечных точек в вебприложении с помощью анализа JS. Работа с сервисами dnsdb scout, shodan, censys. Понимание и использование эксплоитов к различным CVE. Понимание и работа с Apache2 настройка и использование SSL сертификатов, настройка dovecot и postfix, настройка DKIM/SPF/DMARC. Верстка сайтов для фишинга.

Понимание тестирования Android приложений.

Тестирование Wi-fi.

Работа с гипервизорами Hyper-V, ESX. Работа с bad usb.

Общение с заказчиками. Оценка времени на проведение тестирования.

Понимание работы WAF и IDS.

Составление отчетов по проведенным тестированиям.

Ключевые навыки

Black box testing, Тестирование на проникновение, CI/CD, SDL/SDLC, SAST/DAST, OWASP, DevSecOps, Burp Suite

